



Esercizio Epcode Scansione servizi con Nmap pt. 1

ESERCIZIO EPICODE WEEK 11 DAY 1 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	3-6
Conclusione.....	6

Executive Summary

L'attività svolta ha avuto l'obiettivo di analizzare un sistema target Metasploitable utilizzando diverse tecniche di scansione fornite da Nmap. Attraverso l'esecuzione di scansioni di OS fingerprinting, SYN scan, TCP Connect scan e version detection, è stato possibile raccogliere informazioni dettagliate sul sistema operativo, sulle porte aperte e sui servizi in esecuzione.

Le scansioni hanno evidenziato una superficie d'attacco ampia, caratterizzata da numerosi servizi obsoleti e potenzialmente vulnerabili, nonché l'assenza di adeguate misure di sicurezza a livello di rete. I risultati ottenuti dimostrano come strumenti di scanning correttamente utilizzati consentano di ottenere una visione completa del target già nelle fasi iniziali di un penetration test.

Introduzione

Nel contesto della sicurezza informatica, la fase di scanning rappresenta un passaggio fondamentale per comprendere l'assetto di un sistema target prima di eventuali attività di exploitation. Questo esercizio si concentra sull'uso di Nmap, uno degli strumenti più diffusi per la scansione di host e servizi, applicando diverse tecniche di scansione TCP e di identificazione del sistema operativo.

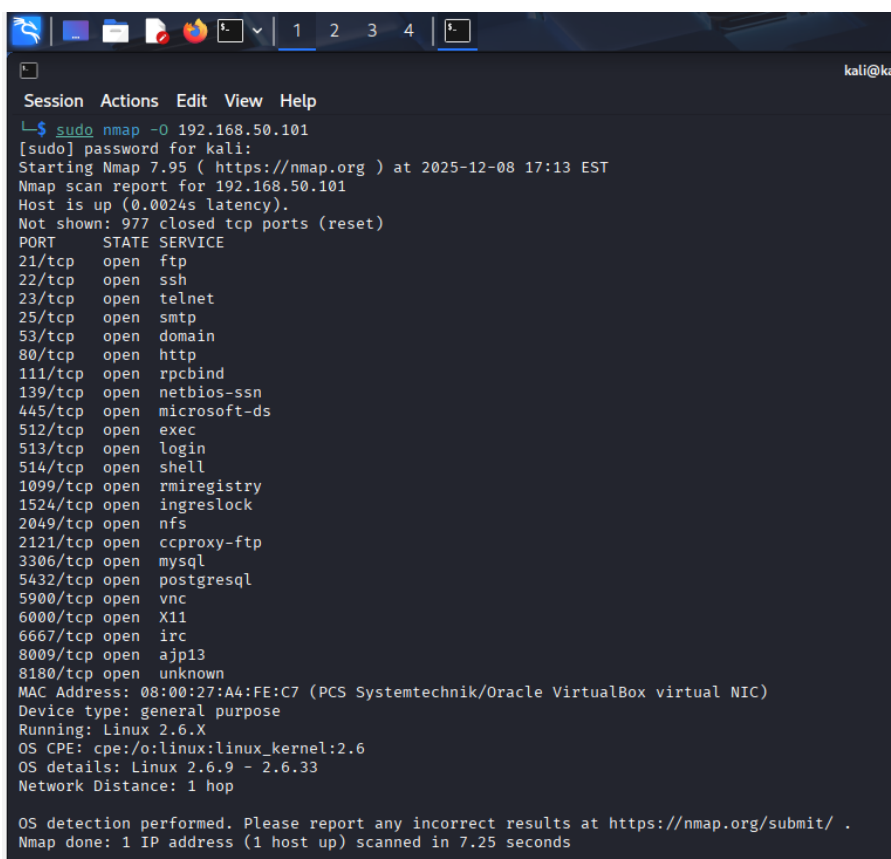
L'ambiente di laboratorio utilizzato è una macchina Metasploitable, progettata deliberatamente per presentare vulnerabilità, configurata su una rete diversa rispetto alla macchina attaccante (Kali Linux), così da simulare uno scenario di scansione inter-rete più realistico. Le attività svolte permettono di confrontare approcci differenti di scansione e di comprenderne l'impatto in termini di affidabilità, rumorosità e informazioni raccolte.

Obiettivo

L'obiettivo principale dell'esercizio è acquisire familiarità con le principali tecniche di scansione offerte da Nmap e comprenderne le differenze operative. In particolare, l'attività mira a identificare il sistema operativo del target, enumerare le porte aperte e i servizi in ascolto, e confrontare i risultati ottenuti tramite SYN scan e TCP Connect scan.

Un ulteriore obiettivo è sviluppare la capacità di interpretare correttamente gli output delle scansioni e sintetizzare le informazioni raccolte all'interno di un report tecnico strutturato, rispettando uno scenario di rete coerente con le richieste della traccia.

Proof of Concept



```
Session Actions Edit View Help
└─$ sudo nmap -O 192.168.50.101
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 17:13 EST
Nmap scan report for 192.168.50.101
Host is up (0.0024s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.25 seconds
```

Questa scansione permette di identificare il sistema operativo del target analizzando il comportamento dello stack TCP/IP. Dai risultati emerge che la macchina utilizza un kernel Linux 2.6.x, informazione coerente con l'ambiente Metasploitable e utile per guidare eventuali fasi successive di exploitation.

```

(kali㉿kali)-[~]
$ sudo nmap -sS 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 17:13 EST
Nmap scan report for 192.168.50.101
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.79 seconds

```

La SYN scan utilizza una tecnica stealth che non completa la connessione TCP, rendendola più rapida e meno evidente rispetto alla TCP Connect scan. L'output mostra le stesse porte aperte, ma con un approccio più discreto, tipico delle fasi iniziali di ricognizione in un penetration test reale.

```

(kali㉿kali)-[~]
$ sudo nmap -sT 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 17:14 EST
Nmap scan report for 192.168.50.101
Host is up (0.0036s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.09 seconds

```

La scansione TCP Connect esegue una connessione completa a ogni porta tramite il three-way handshake. I risultati evidenziano le stesse porte aperte rilevate con altre tecniche, ma questa modalità risulta più rumorosa poiché stabilisce connessioni complete e può essere più facilmente tracciata dai sistemi di logging del target.

```

(kali@kali)-[~]
$ sudo nmap -sV 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 17:16 EST
Nmap scan report for 192.168.50.101
Host is up (0.0024s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Tomcat/Coyote JSP engine 1.1
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:A4:FE:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 58.43 seconds

```

Con questa scansione Nmap viene utilizzato per identificare i servizi in ascolto sul target e le relative versioni. L'output mostra numerosi servizi obsoleti e notoriamente vulnerabili, come vsFTPD 2.3.4, Apache 2.2.8, Samba 3.x e MySQL 5.0, confermando che il sistema espone una superficie d'attacco estremamente ampia.

Conclusione

L'analisi condotta sulla macchina Metasploitable ha permesso di individuare un sistema fortemente esposto, caratterizzato da un kernel Linux obsoleto e da numerosi servizi in ascolto su porte TCP standard e non standard. Le scansioni hanno evidenziato la presenza di servizi come FTP, SSH, Telnet, HTTP, SMB, database MySQL e PostgreSQL, molti dei quali eseguono versioni datate e note per la presenza di vulnerabilità.

Il confronto tra SYN scan e TCP Connect scan ha mostrato come, a parità di porte individuate, le due tecniche differiscano principalmente in termini di rumorosità e modalità di connessione, rendendo la SYN scan più adatta a contesti stealth e la TCP Connect scan più affidabile in assenza di privilegi elevati. Nel complesso, l'esercizio dimostra come una corretta fase di scanning consenta di raccogliere rapidamente informazioni critiche su un target e rappresenti una base essenziale per qualunque attività di penetration testing strutturata.

Venezia, 01/12/2025

Fabio Renna